



API Security Risk Analysis Report

CONFIDENTIAL SECURITY DELIVERABLE

PREPARED BY: Lemina K

ROLE: Cyber Security Intern

ORGANIZATION: Future Interns

DATE: May 2026

1. EXECUTIVE SUMMARY

In the modern digital landscape, Application Programming Interfaces (APIs) serve as the backbone of software connectivity and data exchange. As organizations increasingly adopt SaaS models, the security of these endpoints becomes paramount. Insecure APIs can lead to unauthorized data exposure, system compromise, and significant reputational damage.

A comprehensive, read-only security assessment was conducted on the target API infrastructure. The primary objective was to identify potential vulnerabilities without disrupting service availability. This analysis revealed several security risks, ranging from authentication failures to excessive data exposure. This report outlines these findings and provides actionable remediation strategies to harden the API environment.

2. INTRODUCTION

APIs are sets of protocols that allow different software applications to communicate. They are the gateways through which users and external services interact with an application's core data. Because they are designed to be accessible, they are often prime targets for cyberattacks.

The importance of API security cannot be overstated. Unlike traditional web applications, APIs often expose the underlying business logic and sensitive data structures directly. An insecure API can lead to mass data scraping, account takeovers, and man-in-the-middle attacks. Regular security assessments are essential to identify these gaps before they are exploited by malicious actors.

3. OBJECTIVE

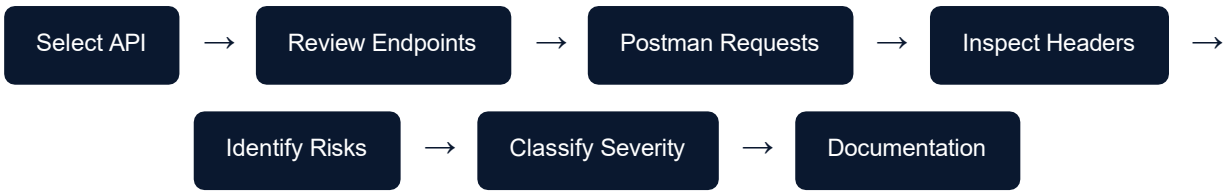
- a. **Endpoint Analysis:** Thoroughly examine all accessible API endpoints for structural weaknesses.
- b. **Risk Identification:** Discover security vulnerabilities such as broken authentication or lack of rate limiting.
- c. **Exposure Assessment:** Evaluate the sensitivity of data being returned in API responses.
- d. **Remediation Guidance:** Provide clear, technical recommendations to mitigate identified risks.

4. SCOPE OF ASSESSMENT

The assessment was strictly limited to the following parameters:

Category	Details
API Tested	https://jsonplaceholder.typicode.com
Type	Read-only API Security Analysis
Tools Used	Postman, Browser DevTools, OWASP ZAP
Allowed Activities	Safe GET requests, Header inspection, Response analysis
Restricted Activities	Exploitation, Authentication bypass, Denial of Service (DoS) testing

5. METHODOLOGY



1. **Selection:** Defining the target environment and ensuring scope compliance.
2. **Endpoint Review:** Mapping out available resources and methods.
3. **Request Execution:** Sending controlled requests to observe server behavior.
4. **Inspection:** Analyzing status codes, response bodies, and security headers.
5. **Risk Classification:** Categorizing findings based on the OWASP API Security Top 10.

6. API ENDPOINTS TESTED

Endpoint	Purpose / Description
/users	Retrieves a comprehensive list of all registered users.
/posts	Retrieves blog posts or public feed content.
/comments	Retrieves user comments associated with posts.
/users/1	Retrieves detailed profile information for a specific user ID.

7. FINDINGS & RISK ANALYSIS

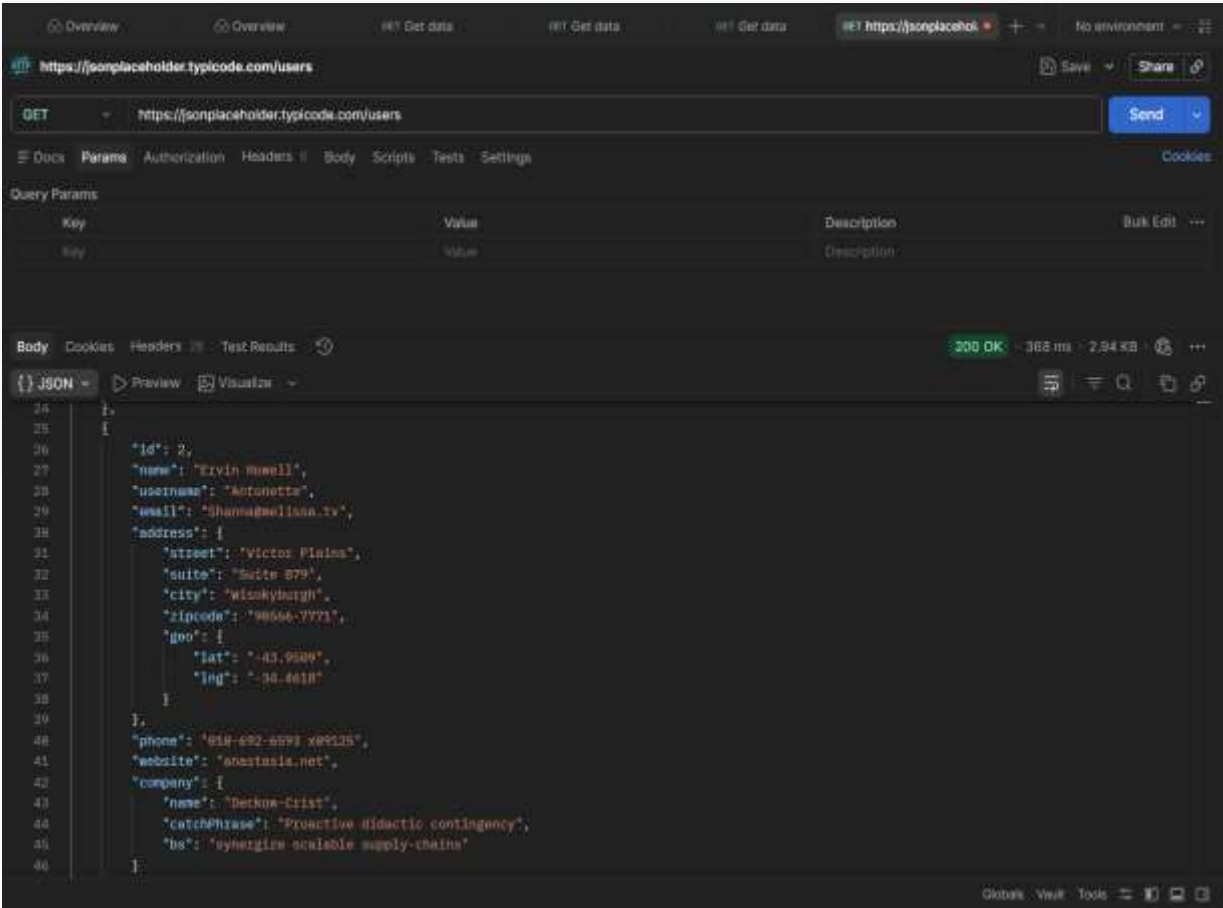
FINDING 1: OPEN API ENDPOINT

HIGH

Description: The API allows complete access to user resources without requiring any form of authentication or identity verification.

Business Impact: Any individual with the URL can access internal user data, leading to potential privacy violations and bulk data collection.

Remediation: Implement industry-standard authentication such as OAuth 2.0 or JWT (JSON Web Tokens) for all sensitive endpoints.



FINDING 2: UNRESTRICTED DATA ACCESS

MEDIUM

Description: The system returns large datasets in a single response without enforced limits or pagination.

Business Impact: Excessive resource consumption on the server and enables efficient scraping of the entire database.

Remediation: Enforce server-side pagination (e.g., `?page=1&limit=20`) and limit the maximum records per request.

The screenshot shows a REST client interface with a GET request to `https://jsonplaceholder.typicode.com/posts`. The response is a large JSON array of 100 posts, indicating unrestricted data access. The response status is 200 OK, and the response size is 7.00 KB.

```
1 {
2   {
3     "userId": 1,
4     "id": 1,
5     "title": "sunt aut facere repellat provident occaecati excepturi optio reprehenderit",
6     "body": "quia et suscipit\nnausciipit recusandae consequuntur expedita et cum\nreprehenderit molestiae ut ut quas tota\nmolestiae repugnat qui voluptate architecto autem sunt non tenet"
7   },
8   {
9     "userId": 1,
10    "id": 2,
11    "title": "qui est esse",
12    "body": "est rerum tempore vitae\nsequi sint nihil reprehenderit dolor beatae ea dolores neque\nfugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis\nqui aperiam non debitis possimus qui neque nisi nulla"
13  },
14  {
15    "userId": 1,
16    "id": 3,
17    "title": "ea molestias quasi exercitationem repellat qui ipsa sit aut",
18    "body": "et lusea sed quo lura\nvoluptates occaecati omnis eligendi aut ad\nvoluptatem doloribus vel accusantium quis pariatur\nmolestiae porro eius odio et labore et velit aut"
19  },
20  }
```

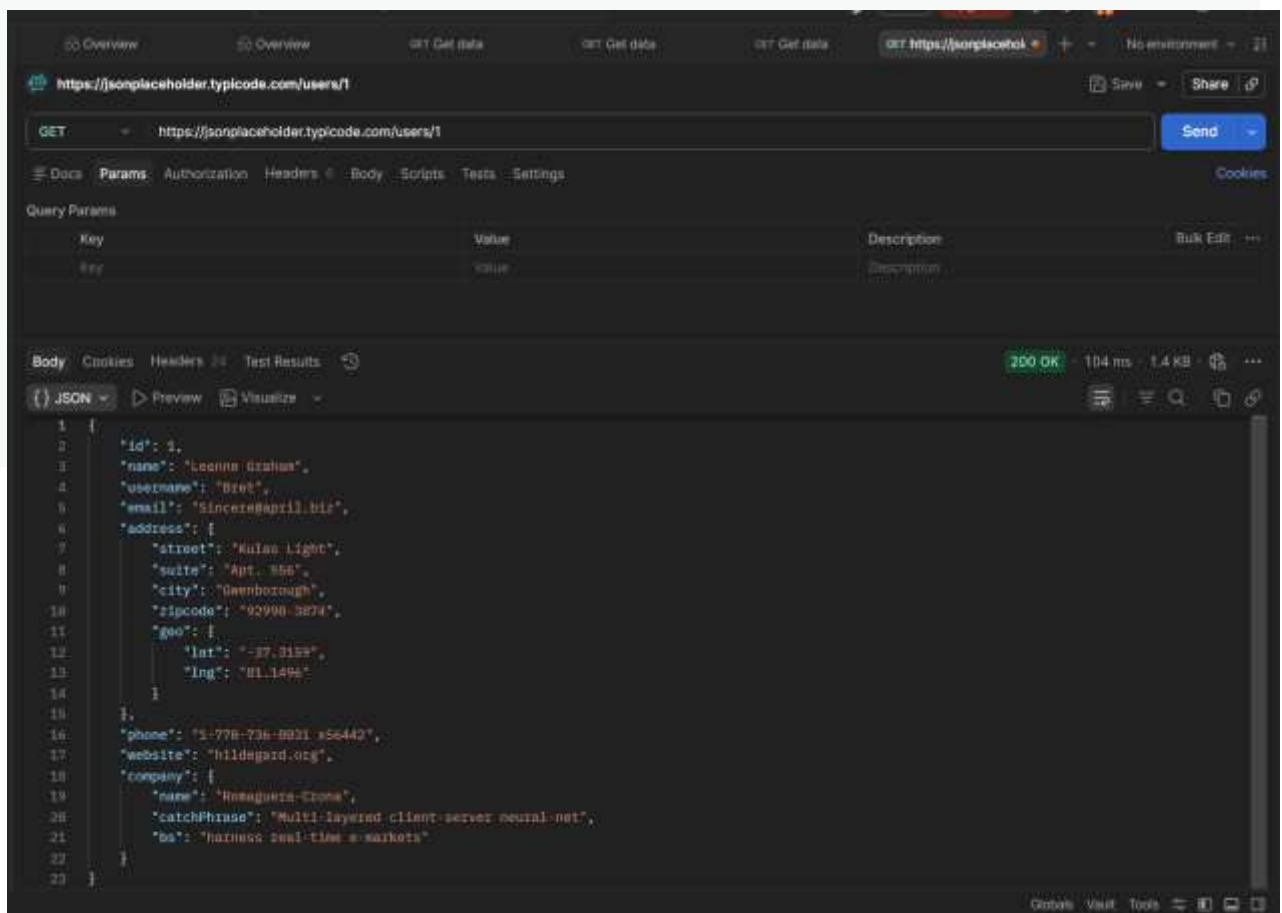
FINDING 3: EXCESSIVE DATA EXPOSURE

HIGH

Description: API responses include sensitive fields (email, address, geolocation) that may not be required by the client application.

Business Impact: Increases the surface area for social engineering and PII (Personally Identifiable Information) leaks.

Remediation: Use Data Transfer Objects (DTOs) to filter and return only the fields necessary for the specific use case.



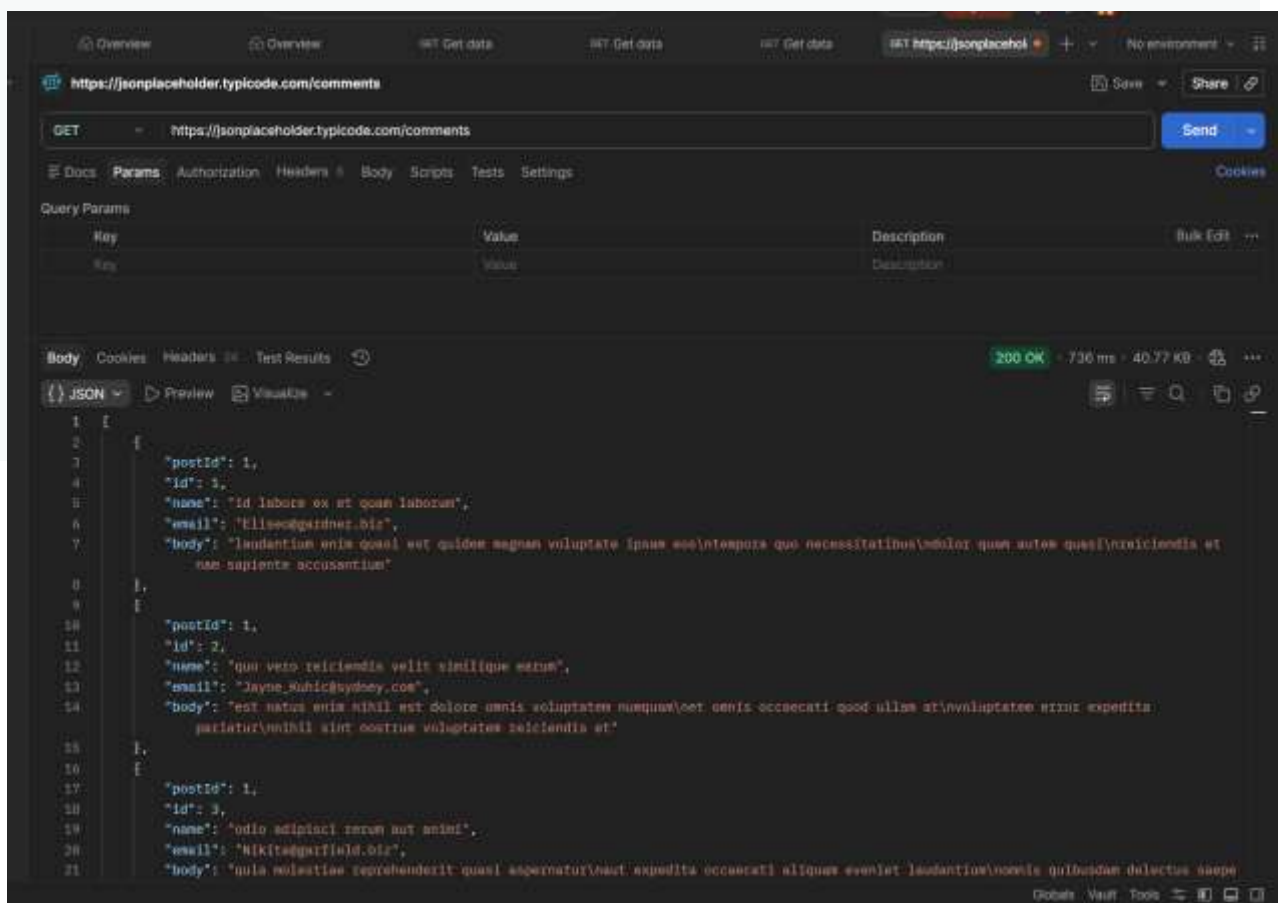
FINDING 4: NO RATE LIMITING

MEDIUM

Description: There are no restrictions on the frequency of requests a single IP address can make to the API.

Business Impact: Vulnerable to brute-force attacks and Denial of Service (DoS) through automated request flooding.

Remediation: Implement rate limiting at the API Gateway level (e.g., 100 requests per minute per API key).



FINDING 5: MISSING SECURITY HEADERS

MEDIUM

Description: The API server fails to send critical security-related HTTP headers in its responses.

Business Impact: Clients are more susceptible to Cross-Site Scripting (XSS) and clickjacking attacks.

Remediation: Configure the server to include Content-Security-Policy, Strict-Transport-Security, and X-Content-Type-Options.

The screenshot shows a REST client interface with the following details:

- Request:** GET `https://jsonplaceholder.typicode.com/users`
- Response:** 200 OK, 159 ms, 2.04 KB
- Headers:**

Key	Value
status	200
date	Tue, 05 May 2020 17:07:45 GMT
content-type	application/json; charset=utf-8
content-length	1847
access-control-allow-credentials	true
cache-control	max-age=43200
content-encoding	gzip
etag	W/"160d-1eM5xwJRfnVLR8mYJSbCUZ1qQ"
expires	-1
nel	{"report_to":"heroku-nel","response_headers":["Via"],"max_age":3600,"success_fraction":0.01...
pragma	no-cache
report-to	{"group":"heroku-nel","endpoints":[{"url":"https://nel.heroku.com/reports?s=F4qtsXM%2FUDK...
reporting-endpoints	heroku-nel="https://nel.heroku.com/reports?s=F4qtsXM%2FUDK2VktU339WgpcYAdskShow...
server	cloudflare

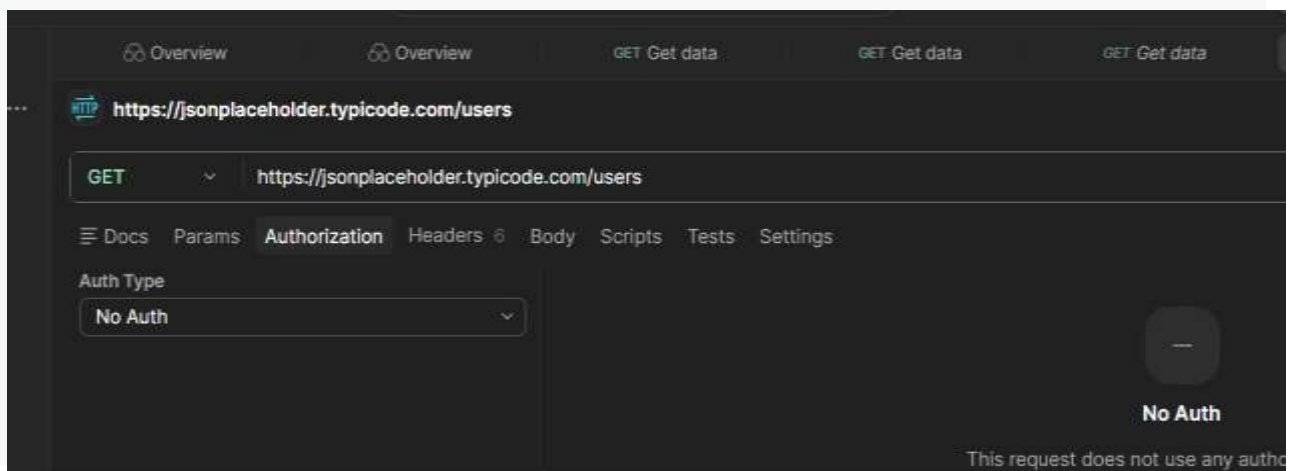
FINDING 6: NO AUTHENTICATION MECHANISM

HIGH

Description: There is no underlying logic to validate identity tokens, even if they were to be sent by a client.

Business Impact: Complete lack of access control allows any entity to query the API as an administrator-level user.

Remediation: Integrate an Identity Provider (IdP) and require Bearer tokens for all non-public routes.



8. RISK SUMMARY TABLE

Ref	Finding Name	Severity Level	Status
F01	Open API Endpoint	HIGH	Open
F02	Unrestricted Data Access	MEDIUM	Open
F03	Excessive Data Exposure	HIGH	Open
F04	No Rate Limiting	MEDIUM	Open
F05	Missing Security Headers	MEDIUM	Open
F06	No Authentication Mechanism	HIGH	Open

9. BUSINESS IMPACT

The vulnerabilities identified pose significant risks to the business operations and regulatory compliance standing:

- a. **Data Privacy & Compliance:** Exposure of PII could lead to violations of GDPR or local data protection laws.
- b. **Reputational Integrity:** Public disclosure of an unsecured API can erode customer trust and damage the brand.
- c. **Operational Continuity:** Lack of rate limiting leaves the infrastructure vulnerable to downtime caused by malicious or accidental traffic spikes.
- d. **Financial Loss:** Potential fines and the cost of incident response far outweigh the cost of proactive security implementation.

10. RECOMMENDATIONS

- ✓ **Implement Strong Authentication:** Deploy JWT or OAuth 2.0 across all endpoints.
- ✓ **Role-Based Access Control (RBAC):** Ensure users can only access data they are authorized to see.
- ✓ **Response Filtering:** Review all API schemas and remove unnecessary sensitive fields.
- ✓ **Throttling & Quotas:** Apply rate limits to prevent automated abuse.
- ✓ **Security Headers:** Update server configurations to include modern security protection headers.
- ✓ **Continuous Monitoring:** Implement logging and alerting for unusual API traffic patterns.

11. CONCLUSION

API security is a critical component of the modern SaaS security posture. The current assessment of the target environment has highlighted several critical and medium-level risks that must be addressed to ensure data integrity and service availability. By implementing the suggested remediations, the organization can significantly harden its API infrastructure against unauthorized access and common web-based threats.

End of Report